

S10_L5 – Infrastruttura IT di AC, Configurazione Active Directory e Sicurezza

Introduzione

Il presente documento illustra in modo strutturato le attività di configurazione eseguite sull'infrastruttura IT dell'azienda AC, con riferimento al dominio AC-SRV-EU-IT.local, operativo nella Zona geografica Z1. L'intervento ha riguardato la progettazione e l'implementazione di una struttura di Active Directory conforme alle best practice Microsoft, la definizione di gruppi di sicurezza, l'assegnazione granulare dei permessi sulle risorse condivise, la distribuzione centralizzata del software e la configurazione di politiche di sicurezza per gli utenti finali.

Gli obiettivi principali del progetto sono stati:

- Garantire il rispetto del principio di minimo privilegio (Least Privilege) per tutti gli utenti e i servizi.
- Centralizzare la gestione delle policy di sicurezza tramite Group Policy Objects (GPO).
- Abilitare il monitoraggio degli eventi di sicurezza tramite Splunk Universal Forwarder.
- Semplificare l'onboarding di nuove workstation tramite il meccanismo di pre-staging Active Directory.

Struttura Organizzativa delle Unità Organizzative (OU)

Architettura delle OU

Al fine di garantire una gestione granulare delle policy e una chiara separazione delle responsabilità amministrative, è stata progettata e implementata la seguente struttura gerarchica di Unità Organizzative all'interno del dominio

Percorso OU	Contenuto	Scopo
OU=AC	Root aziendale	Contenitore principale di tutti gli oggetti aziendali

Percorso OU	Contenuto	Scopo
OU=Z1	Zona geografica	Separazione per espansione futura (Z2, Z3...)
OU=Users\IT	Utenti reparto IT	Applicazione policy amministrative IT
OU=Users\Directors	Utenti Direttori	Applicazione restrizioni e mapping drive
OU=Users\Developers	Utenti Sviluppatori	Applicazione restrizioni e mapping drive
OU=Workstations\IT	PC reparto IT	Policy workstation per amministratori
OU=Workstations\Directors	PC Direttori	Policy workstation per direttori
OU=Workstations\Developers	PC Sviluppatori	Policy workstation per sviluppatori
OU=Servers	Server aziendali	Policy specifiche per i server
OU=ServiceAccounts	Account di servizio	Isolamento account tecnici (es. Splunk)

Gruppi di Sicurezza Creati

Global Groups (GG)

I Global Groups raccolgono gli utenti per reparto e costituiscono il primo livello del modello AGDLP adottato. Ogni utente viene inserito nel gruppo corrispondente al proprio reparto di appartenenza.

Nome Gruppo	Tipo	Reparto	Descrizione
GG_IT	Global Security	IT	Raggruppa tutti i membri del reparto IT. Garantisce diritti amministrativi sulle workstation e accesso RDP al Domain Controller.
GG_Directors	Global Security	Direzione	Raggruppa i Direttori aziendali. Consente l'accesso alla cartella condivisa riservata alla direzione.

Nome Gruppo	Tipo	Reparto	Descrizione
GG_Developers	Global Security	Sviluppo	Raggruppa gli Sviluppatori. Consente l'accesso alla cartella condivisa riservata al team di sviluppo.

Domain Local Groups (DL)

I Domain Local Groups vengono assegnati direttamente ai permessi NTFS delle risorse condivise. Questa separazione garantisce scalabilità e facilità di manutenzione: per modificare i permessi su una risorsa è sufficiente agire sui DL, senza toccare i singoli utenti.

Nome Gruppo	Tipo	Risorsa Associata	Permesso NTFS
DL_DirectorsFolder_RW	Domain Local Security	\\AC-SRV-EU-IT-Z1\Directors	Modify (Lettura/Scrittura)
DL_DevelopersFolder_RW	Domain Local Security	\\AC-SRV-EU-IT-Z1\Developers	Modify (Lettura/Scrittura)

Account di Servizio

In conformità al principio di minimo privilegio, è stato creato un account di servizio dedicato per l'esecuzione del processo Splunk Universal Forwarder, privo di diritti amministrativi e con accesso limitato alle sole risorse strettamente necessarie.

Account	Tipo	OU	Scopo
svc_splunkfwd	Service Account	OU=ServiceAccounts	Esecuzione del servizio Splunk Universal Forwarder sui client di dominio. Membro del gruppo Lettori Registro Eventi.

Permessi Assegnati a Ciascun Gruppo

Gruppo GG_IT — Reparto Information Technology

Risorsa / Ambito	Permesso	Meccanismo
Tutte le workstation in OU=Workstations (IT, Directors, Developers)	Amministratore locale	GPO: GPO_IT_LocalAdminRights

Risorsa / Ambito	Permesso	Meccanismo
Domain Controller (AC-SRV-EU-IT-Z1)	Accesso RDP	Gruppo Remote Desktop Users + Firewall rule 3389
Cartella \\AC-SRV-EU-IT-Z1\Directors	Full Control (NTFS)	Assegnazione diretta NTFS
Cartella \\AC-SRV-EU-IT-Z1\Developers	Full Control (NTFS)	Assegnazione diretta NTFS
Pre-staging workstation AD	Join workstation pre-staged	Delega ACL su oggetti computer

Gruppo GG_Directors — Reparto Direzione

Risorsa / Ambito	Permesso	Meccanismo
Cartella \\AC-SRV-EU-IT-Z1\Directors (via DL_DirectorsFolder_RW)	Modify (Lettura/Scrittura)	AGDLP: GG_Directors → DL_DirectorsFolder_RW
Drive D: (mapping automatico)	Accesso alla cartella Directors	GPO: GPO_Directors_DriveMapping
Pannello di Controllo Windows	ACCESSO NEGATO	GPO: GPO_Directors_Restrictions
Microsoft Edge	UTILIZZO NEGATO	GPO: GPO_Directors_Restrictions (msedge.exe bloccato)

Gruppo GG_Developers — Reparto Sviluppo

Risorsa / Ambito	Permesso	Meccanismo
Cartella \\AC-SRV-EU-IT-Z1\Developers (via DL_DevelopersFolder_RW)	Modify (Lettura/Scrittura)	AGDLP: GG_Developers → DL_DevelopersFolder_RW

Risorsa / Ambito	Permesso	Meccanismo
Drive E: (mapping automatico)	Accesso alla cartella Developers	GPO: GPO_Developers_DriveMapping

Account svc_splunkfwd — Servizio Splunk

Risorsa / Ambito	Permesso	Meccanismo
Avvio come servizio Windows	Log on as a service	GPO: GPO_SplunkForwarder_ServiceAccount
Log di sicurezza e di sistema Windows	Lettura	Gruppo locale Lettori Registro Eventi (via GPO)
Cartella installazione Splunk UF (var, etc)	Modifica	ACL NTFS diretta

Group Policy Objects Configure

Nome GPO	Linkata a	Tipo	Funzione
GPO_IT_LocalAdminRights	OU=Workstations	Computer Config.	Aggiunge GG_IT al gruppo Administrators locale di tutte le workstation di Z1
GPO_Directors_DriveMapping	OU=Directors,OU=Users	User Config.	Mappa il drive D: su \\server\Directors per gli utenti del gruppo GG_Directors
GPO_Developers_DriveMapping	OU=Developers,OU=Users	User Config.	Mappa il drive E: su \\server\Developers per gli utenti del

Nome GPO	Linkata a	Tipo	Funzione
			gruppo GG_Developers
GPO_Directors_Restrictions	OU=Directors,OU=Users	User Config.	Blocca l'accesso al Pannello di Controllo e impedisce l'esecuzione di Microsoft Edge
GPO_SplunkForwarder_ServiceAccount	OU=Workstations	Computer Config.	Assegna il diritto Log on as a service e l'appartenenza al gruppo Lettori Registro Eventi a svc_splunkfwd
GPO_Software_Firefox	OU=Workstations	Computer Config.	Distribuisce Mozilla Firefox ESR tramite Startup Script; abilita l'esecuzione di script PowerShell
GPO_DC_RemoteAccess	OU=Domain Controllers	Computer Config.	Abilita l'accesso RDP al DC e apre la porta 3389 nel firewall per il profilo Domain
GPO_Splunk_Firewall_Server	OU=Servers	Computer Config.	Apre le porte 9997, 8089 e 8000 per la comunicazione con Splunk Enterprise
GPO_Splunk_Firewall_Client	OU=Workstations	Computer Config.	Abilita il traffico outbound verso il server Splunk sulle porte 9997 e 8089

Distribuzione e Configurazione Splunk

Architettura di Monitoraggio

Al fine di garantire visibilità sugli eventi di sicurezza e di sistema, è stato implementato Splunk Enterprise sul server AC-SRV-EU-IT-Z1, affiancato da Splunk Universal Forwarder sui client di dominio. La distribuzione della configurazione avviene tramite il meccanismo di Deployment Server integrato in Splunk Enterprise.

Componente	Macchina	Porta	Funzione
Splunk Enterprise (Indexer)	AC-SRV-EU-IT-Z1	9997	Riceve e indicizza i dati provenienti dai forwarder
Splunk Enterprise (Deployment Server)	AC-SRV-EU-IT-Z1	8089	Distribuisce la configurazione ai Universal Forwarder
Splunk Web UI	AC-SRV-EU-IT-Z1	8000	Interfaccia di ricerca e analisi degli eventi
Splunk Universal Forwarder	Client di dominio	—	Raccoglie gli eventi Windows e li invia all'indexer

Log Raccolti

La Deployment App `app_win_eventlog`, distribuita tramite Deployment Server, configura la raccolta dei seguenti log su ogni client di dominio:

Sorgente Log	Index Splunk	Event ID Monitorati
Security Event Log	win_security	4624, 4625, 4634, 4647, 4648, 4688, 4720, 4722, 4724, 4740, 4768, 4776, 7045
System Event Log	win_system	41, 1001, 1074, 6005, 6006, 6008, 7034, 7036, 7040, 7045

Problematiche Riscontrate e Relative Risoluzioni

Firewall blocca le comunicazioni Splunk

Durante la fase di configurazione del forwarder, nonostante la corretta installazione del servizio, non era visibile alcun dato nella Splunk Web UI. L'analisi dei log ha rivelato che nessun forwarder si era mai connesso al server.

- **Causa:** Le porte TCP 9997 e 8089 non erano aperte nel firewall di Windows del server.
- **Soluzione:** Sono state create regole firewall specifiche tramite PowerShell per le porte necessarie, successivamente formalizzate in una GPO dedicata applicata alla OU dei server.

Mancata ricezione della Deployment App da parte del forwarder

Il Universal Forwarder contattava regolarmente il Deployment Server (log phoneHome ogni 60 secondi), ma non riceveva alcuna configurazione.

- **Causa:** La Server Class nel Deployment Server non era stata configurata, pertanto nessuna app veniva associata ai client.
- **Soluzione:** È stata creata la Server Class Windows_Clients con l'associazione dell'app app_win_eventlog. Successivamente è stato eseguito il reload del Deployment Server.

Sintassi errata nel file inputs.conf

Dopo la corretta ricezione della Deployment App, il forwarder non raccoglieva alcun evento dai log di Windows.

- **Causa:** La direttiva whitelist all'interno di inputs.conf era stata scritta con la sintassi SPL (linguaggio di ricerca Splunk), non valida per i file di configurazione. Dopo una lettura della documentazione, è stato notato che il formato corretto prevede un elenco di Event ID separati da virgola.
- **Soluzione:** Il file inputs.conf è stato corretto sul Deployment Server con la sintassi whitelist = 4624,4625,... e ridistribuito ai client.

Permessi insufficienti per la lettura del Security Log

Il Universal Forwarder, in esecuzione con l'account `svc_splunkfwd`, non disponeva dei permessi necessari per accedere al Security Event Log di Windows, protetto per impostazione predefinita.

- **Causa:** L'account `svc_splunkfwd` non era membro del gruppo locale Lettori Registro Eventi.
- **Soluzione:** È stata configurata una GPO che aggiunge `svc_splunkfwd` al gruppo Lettori Registro Eventi su tutte le workstation del dominio. La scelta di operare tramite GPO, anziché manualmente, garantisce l'applicazione automatica su ogni nuova workstation aggiunta al dominio.

Impossibilità di aggiungere il client al dominio

Il tentativo di eseguire il join del client Windows 11 al dominio `AC-SRV-EU-IT.local` risultava in un errore: Il dominio specificato non esiste o è impossibile contattarlo.

- **Causa:** Windows 11 utilizza il protocollo mDNS (Multicast DNS) per risolvere i nomi con suffisso `.local`, intercettando le query prima che raggiungano il server DNS configurato. Il comando `nslookup`, che bypassa il DNS Client di Windows, funzionava correttamente, mentre `Resolve-DnsName` e `Add-Computer` fallivano.
- **Soluzione:** È stato configurato esplicitamente il suffisso DNS tramite `Set-DnsClientGlobalSetting`, riavviato il servizio DNS Client e svuotata la cache. Il join è stato completato con successo.

Software Installation GPO non funzionante su Windows 11

La distribuzione di Mozilla Firefox tramite il meccanismo Software Installation di GPO non ha prodotto l'installazione automatica sui client Windows 11.

- **Causa:** Si assume che Windows 11 utilizza Fast Boot (avvio rapido) per impostazione predefinita, ibernando il kernel invece di eseguire un ciclo di avvio completo. Il processo di Software Installation GPO viene eseguito esclusivamente durante un cold boot reale, che con Fast Boot attivo non si verifica mai, pertanto bloccando l'installazione automatica.
- **Soluzione:** Il metodo di distribuzione è stato sostituito con uno Startup Script PowerShell, più robusto e compatibile con Windows 11. Lo script verifica

preventivamente se Firefox è già installato ed esegue l'installazione silenziosa tramite msixexec.exe, registrando ogni operazione in un log dedicato.

Misure di Sicurezza Adottate

Principio di Minimo Privilegio

Ogni account, gruppo e servizio è stato configurato con il set minimo di permessi necessario per svolgere le proprie funzioni. In particolare:

- L'account di servizio svc_splunkfwd non dispone di diritti amministrativi e può accedere esclusivamente ai log di sistema.
- Il tecnico IT può effettuare il join di workstation pre-staged senza necessità di credenziali Domain Admin.
- I Direttori non hanno accesso al Pannello di Controllo né possono utilizzare Microsoft Edge.

Modello AGDLP per la Gestione dei Permessi

La gestione dei permessi sulle cartelle condivise segue il modello AGDLP (Account → Global Group → Domain Local Group → Permission), che garantisce scalabilità, facilità di manutenzione e tracciabilità delle autorizzazioni.

Monitoraggio degli Eventi di Sicurezza

Tramite Splunk Universal Forwarder, tutti i client di dominio trasmettono in tempo reale gli eventi critici di sicurezza e di sistema al server Splunk Enterprise. Gli event ID monitorati coprono scenari quali accessi non autorizzati, modifiche agli account, creazione di servizi e riavvii imprevisti.

Conclusioni e Prossimi Passi

L'infrastruttura Active Directory dell'azienda AC, Zona Z1, è stata configurata seguendo le best practice Microsoft per ambienti enterprise. La struttura implementata garantisce:

- Separazione chiara dei ruoli e dei permessi tra i reparti IT, Direzione e Sviluppo.
- Gestione centralizzata delle policy di sicurezza tramite GPO.
- Monitoraggio continuo degli eventi di sicurezza tramite Splunk.
- Scalabilità per future espansioni geografiche (Zone Z2, Z3) o organizzative.